

Authentification

JWT (JSON Web Token) est utilisé pour authentifier les utilisateurs. Le token est généré à la connexion, signé avec une clé secrète et a une durée de vie d'1 heure (`jwt.expiration=3600000`). Chaque requête API vérifie la présence et la validité du token via le `JwtFilter`.

Mots de passe

Les mots de passe sont hashés avec BCrypt via `BCryptPasswordEncoder` — jamais stockés en clair. La taille minimale est de 6 caractères.

Autorisation par rôle

Trois rôles sont définis : `client`, `caisse`, `cuisine`. Le rôle est stocké dans le token JWT et vérifié côté React via `RoleRoute` pour bloquer l'accès aux pages non autorisées. Côté back, la suppression de pizzas vérifie le rôle `cuisine` via `JwtUtil.extractRole()`.

Validation des entrées

`@Valid` + `RegisterRequest` valident les données à l'inscription : username entre 6 et 20 caractères, sans caractères spéciaux, mot de passe minimum 6 caractères, email valide. Le `@ExceptionHandler` retourne des messages d'erreur clairs.

Unicité des données

Username et email sont uniques en base (`unique = true`) et vérifiés avant insertion.

Configuration Spring Security

CSRF désactivé (API stateless), sessions désactivées (`STATELESS`), CORS configuré pour autoriser uniquement le front React, headers CSP configurés, cookies `HttpOnly` et `Secure`